SIM Global Education

Professional Practice for Computer Scientists

CM2045

Part B –Risk Management and Security

Lecture 8

By Mel M.H Goh

SIM Global Education

❑ Learning Objectives

- Apply risk management frameworks, to assess security risks and ensure compliance with industry standards.
- Analyse cybersecurity threats and evaluate effective risk mitigation strategies to protect information systems.
- Describe the fundamental principles of risk management in computing, including identifying and assessing potential risks..

❑ Recap from lecture 7 - core principles of information security

- **Confidentiality:**
  - ➢ Restricting access to authorized individuals
- **Integrity:**
  - ➢ Maintaining accuracy and completeness
- **Availability:**
  - ➢ Ensuring access when required.
- Known collectively as the **CIA Triad.**

❑ What is cybersecurity?

This Photo by Unknown Author is licensed under CC BY-ND

- "Cybersecurity is the preservation of **confidentiality, integrity** and **availability** of information in the Cyberspace."

  (Source: ISO/IEC 27032:2012)

- "The ability to protect or defend the use of cyberspace from cyber attacks."

  (Source: NIST Cybersecurity Framework v1.1)

- "Cybersecurity comprises all activities necessary to protect network and information systems, the users of such systems, and other persons affected by cyber threats." (Source: ENISA Glossary)

❑ Key elements of cybersecurity protection

- **Access control** : Usability vs security - easy to use/access may risk compromising security!
- **Intrusion prevention** : Systems and tools designed to detect and block unauthorized access attempt.
- **Encryption** : Data-at-rest encryption and data-in-transit encryption.
- **Privacy safeguards**: Policies and measures to ensure personal and sensitive information is protected.

These elements Involve:

People, Technology, Processes

Fundamentals of cybersecurity

❑ Cybersecurity domain

- Network security
- Information security
- Application security
- Business continuity & disaster recovery
- Operational security
- Leadership commitment
- End-user education

This Photo by Unknown Author is licensed under CC BY-SA

❑ Global cybersecurity landscape (2024)

- **Global spending**:

➢ $183.9 billion in 2024, expected to reach $212 billion in 2025.
(Gartner, 2024) Source:

- **Cybercrime losses**:

➢ Cybercrime cost individuals and businesses **$12.5 billion globally** in 2023; **$16 billion** in 2024 (↑33%).
(FBI via Reuters, April 2025) Source: Reuters

- **Average data breach cost**:

➢ $4.88 million globally in 2024; ransomware breaches averaged $5.13 million.
(IBM Security via PacketLabs, 2024) Source: PacketLabs

❑ Cybersecurity in Singapore (2024)

- **Volume of cyber threats**:

➢ 574,292 threats recorded in H1 2024 — lowest in Southeast Asia. *(Singapore Business Review, Aug 2024)* Source: Singapore Business Review

- **Singapore as a threat source**:

➢ Over 21 million attacks originated from Singapore-based servers; top in SEA and 8th globally. *(Kaspersky via SecurityBrief Asia, 2024)* Source: SecurityBrief Asia

- **Financial losses from cybercrime**:

➢ S$651.8 million lost to scams and cybercrime in 2023 across 46,000+ cases. *(Singapore Police Force via Wikipedia, 2024)* Source: Wikipedia – Crime in Singapore

❑ Case Study – Equifax data breach (2017)

This Photo by Unknown Author is licensed under CC BY-NC-ND

- Equifax Inc., major consumer credit reporting agencies in US.
- Impact of data breach: ~147 million individuals' records exposed.
- Stolen data: Social Security Numbers, dates of birth, addresses, credit card numbers e.t.c
- **Security failures:**

➢ Unpatched Apache struts vulnerability exploited by attackers.

➢ Inadequate asset management – Equifax did not know which systems were affected.

➢ Lack of timely patching, despite public vulnerability disclosure.

➢ Poor internal communication and delayed breach response.

SIM Global Education

❑ Case Study – SingHealth data breach (2018)

https://www.youtube.com/watch?v=aereWuOdWQk&t=12

❑ Case Study – SingHealth data breach (2018)

- SingHealth is Singapore's largest group of healthcare organization.
- Impact of data breach: 1.5 million patient records exposed.
- Stolen data: Names, NRIC numbers, addresses, gender, race, birth dates. Outpatient medication records for 160,000 individuals
- **Security failures:**

➢ Advanced persistent threat (APT) actors gained initial access through a phishing attack

➢ Delayed incident detection and response.

➢ Lack of timely patching and inadequate network segmentation.

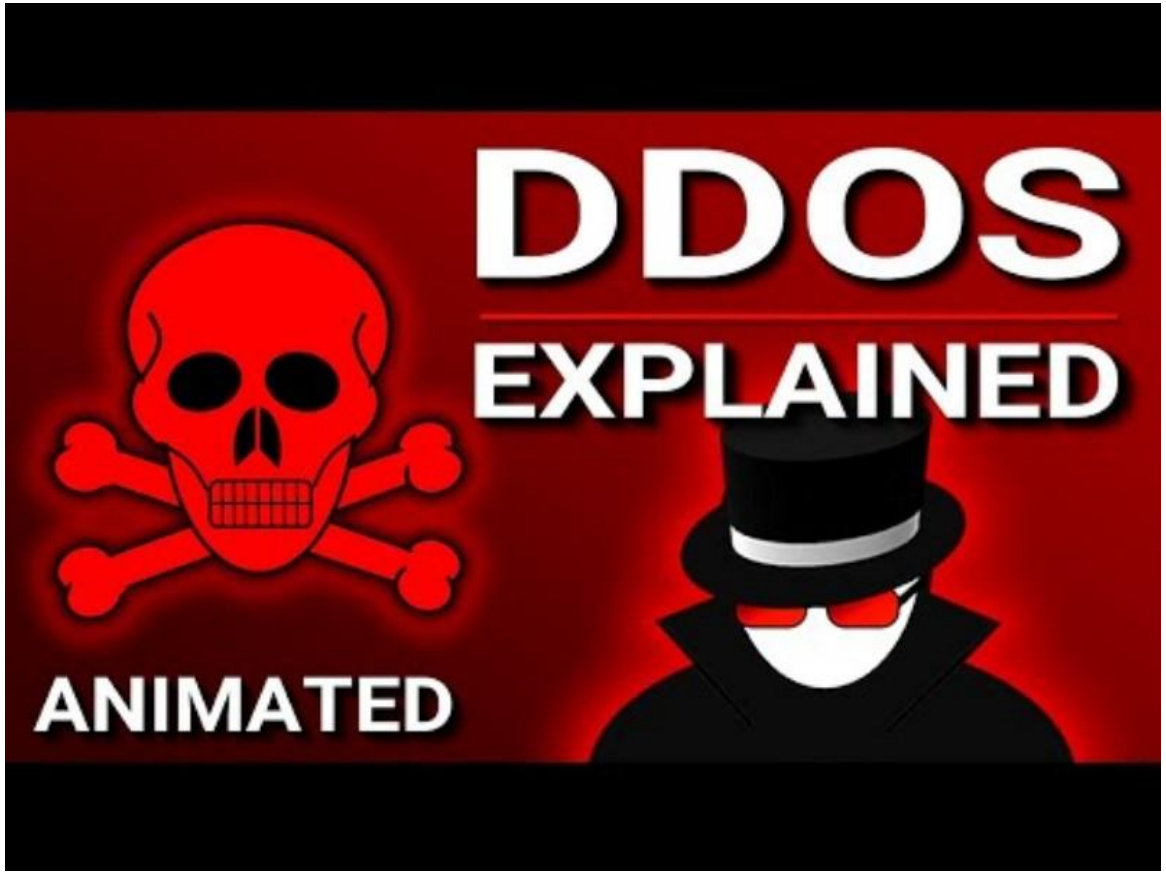
❑ Objectives of cyberattacks

- Damaging the brand value of the other party.
- Inflicting damages (e.g. financial loss) through cyberterrorism.
- Obtaining government and business secrets.
- Warfare cyberattacks. .

❑ Types of cyber threats

- Malware
- Ransomware
- Phishing
- SQL Injection
- DoS/DDoS
- MITM (Man-in-the-Middle)
- Cyberterrorism
- Social engineering (e.t.c)

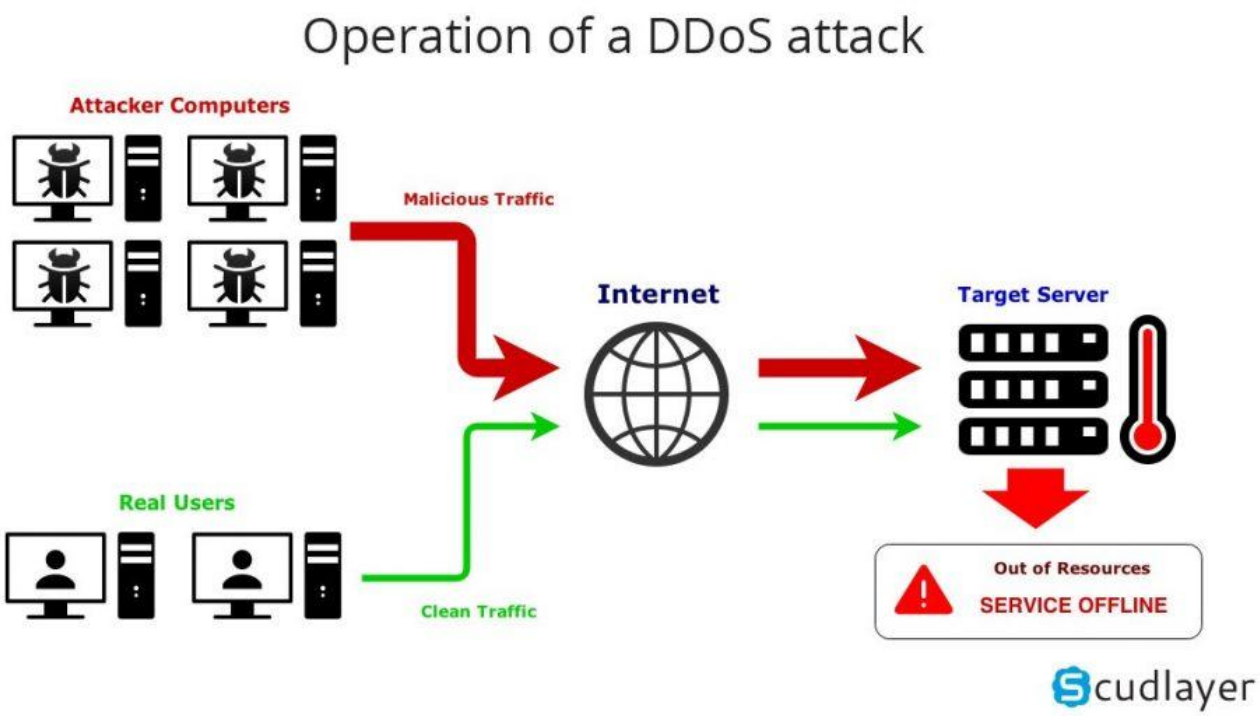
❑ DDOS Explained



https://www.youtube.com/watch?v=ilhGh9CEIwM

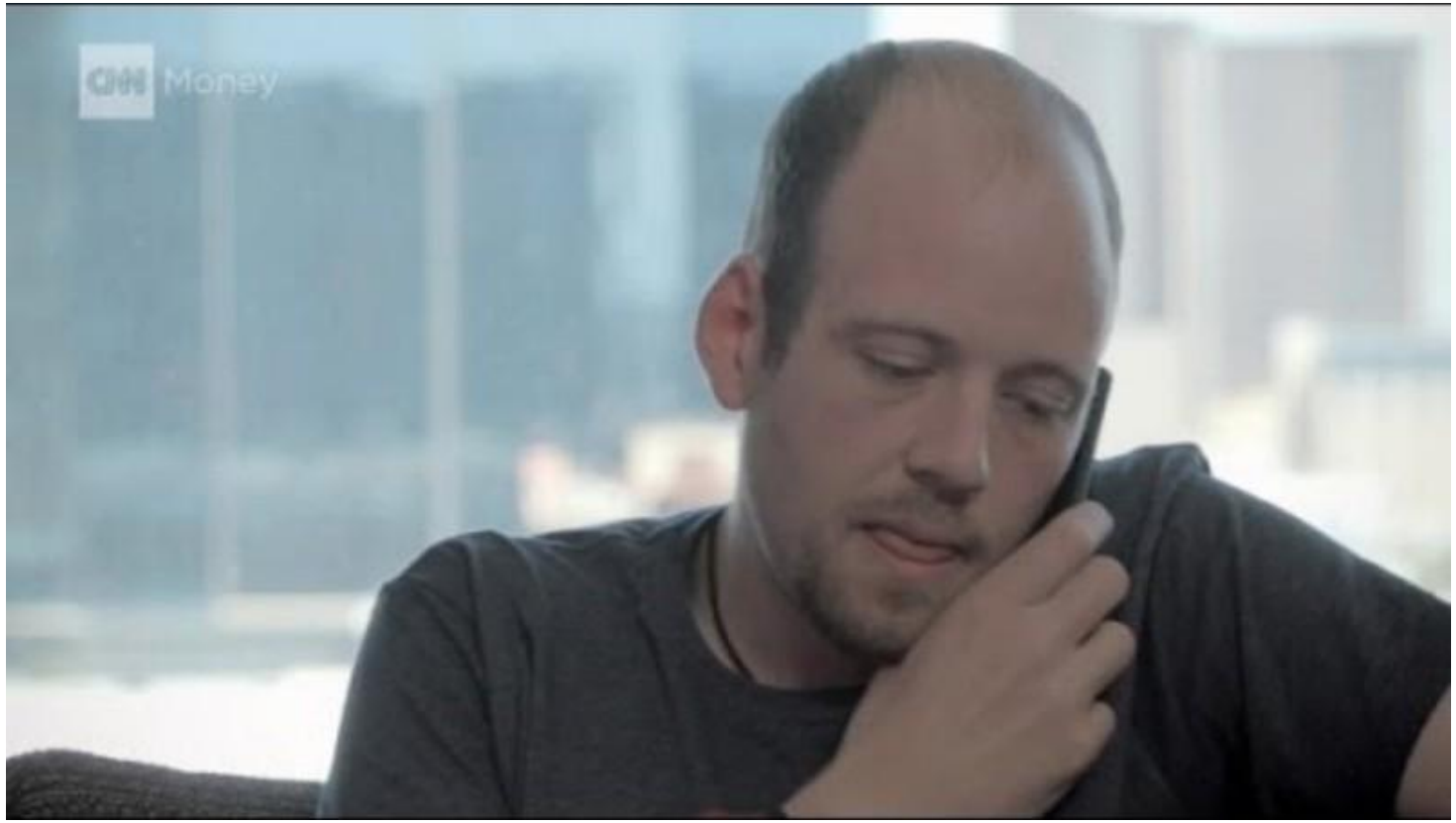
❑ Denial of Service (DoS)

- Attack by Overloading system with traffic.
- Symptoms:
  - ➢ Website unavailability
  - ➢ Slow service
  - ➢ Spam flood
- **Distributed DoS (DDoS)**
  - ➢ DoS attack using multiple sources (botnets
  - ➢ Harder to mitigate
  - ➢ Attacks launched from "zombie" systems
  - ➢ Examples: DNS amplification, volumetric attacks



This Photo by Unknown Author is licensed under CC BY-NC

- **Social engineering example - Watch this hacker break into a company**



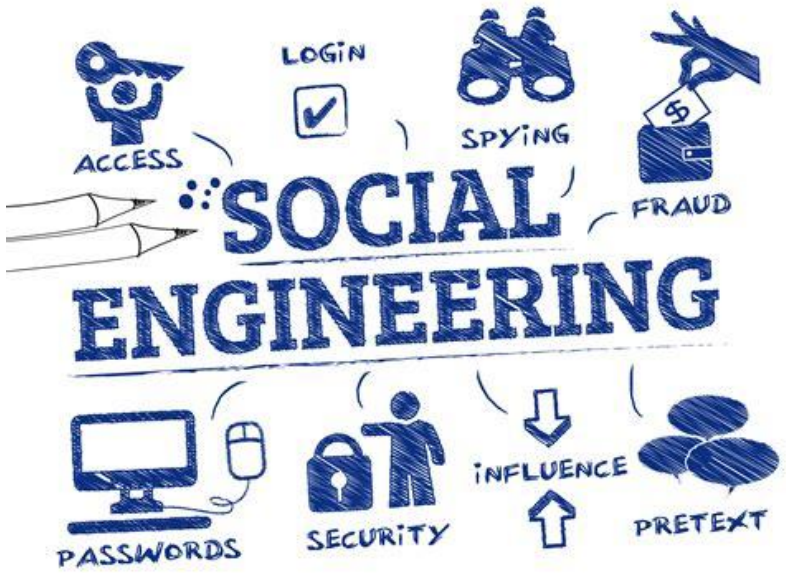
https://www.youtube.com/watch?v=PWVN3Rq4gzw

❑ What is social engineering?

- "Social engineering is the art of manipulating people so they give up confidential information."

  Source: CISA, 2023

- ➢ Exploits **human behaviour** rather than technical vulnerabilities
- ➢ Relies on trust, urgency, fear, or authority to deceive
- **Common Goals:**
- ➢ Steal credentials
- ➢ Gain unauthorized access
- ➢ Spread malware
- ➢ Harvest sensitive information



This Photo by Unknown Author is licensed under CC BY-SA-NC

SIM Global Education

❑ Types of social engineering attacks

Attack Type	Description	Example Scenario
Phishing	Fraudulent emails tricking users into revealing data.	“Urgent account alert” email from a fake bank.
Pretexting	Attacker invents a scenario to gain trust and information.	Pretending to be IT support to get passwords.
Baiting	Offering something tempting to trick a victim.	Free USB drive with malware left in a lobby.
Tailgating	Gaining physical access by following authorized personnel.	Someone holds the door open at a secure site.
Quid pro quo	Promising a service in exchange for information.	“Tech support” offering help for login data.

Source: NIST SP 800-61 Rev. 2, CISA

❑ Case Study: Twitter Hack (2020)

https://www.youtube.com/watch?v=Kp86OAYDw0Y

❑ Case Study: Twitter Hack (2020)

- Attackers used social engineering on Twitter employees to gain access to internal tools
- Method used: Posed as IT staff via phone calls (pretexting)
- Result: Compromised high-profile accounts (Elon Musk, Obama, etc.)
- Impact: Fake tweets promoted a Bitcoin scam; over $100,000 stolen.
- Source: BBC, “Twitter hack: What went wrong?”

❑ How to defend against social engineering

- **Awareness and training**: Educate employees on red flags (e.g., suspicious emails, unexpected requests).
- **Verification**: Always verify identities before sharing sensitive information.
- **Policies and procedures**

➢ Use clear incident reporting systems.

➢ Enforce access controls and password hygiene.

- **Simulated attacks:** Conduct phishing simulations to train users.

Source: KnowBe4 Security Training, NIST Cybersecurity Framework

Supply chain cybersecurity risks

❑ Understanding supply chain cybersecurity risks

- Modern attacks exploit the supply chain software, including third-party or open-source libraries.
- Supply chains are integral to organizational operations.
- Once compromised may lead to data breaches, financial losses, and reputational damage.
- **Common vulnerabilities in supply chains**

➢ Lack of visibility into third-party security practices.

➢ Inadequate contractual security obligations.

➢ Over-reliance on suppliers without proper risk assessments.

➢ Insufficient incident response planning involving suppliers.

This Photo by Unknown Author is licensed under CC BY-SA-NC

Supply chain cybersecurity risks

❑ Understanding supply chain cybersecurity risks

- The surge in supply chain cyber attacks: **increased by 431% between 2021 and 2023.**
- Based on 46 million SMEs surveyed in the US, UK and Japan. Source: (Snape, 2025)
- The trend is expected to continue rising through 2025.
- **Key drivers:**

➢ Rapid digitization and interconnectivity.

➢ Complexity of modern supply chains.

➢ High-value targets accessible through single entry points.

➢ Limited visibility and control over third-party security practices

This Photo by Unknown Author is licensed under CC BY-NC

Supply chain cybersecurity risks

❑ Understanding supply chain cybersecurity risks

- **Who Is most vulnerable?**

➢ **Large Enterprises:** Companies with revenues exceeding $50 million are 2.5 times more likely to face cyber incidents.

➢ **Manufacturing sector:** Cyber risk scores 11.7% below the global average, driven by reliance on automation and exposure of intellectual property.

➢ **Public administration & education:** 70% increase in ransomware attacks on educational institutions over the past year.

- Source: (Snape, 2025)

Supply chain cybersecurity risks

❑ Five-step approach to assessing supply chain cybersecurity

- Understand why your organisation should care.
- Develop an approach to assess supply chain cyber security.
- Apply the approach to new supplier relationships.
- Integrate the approach into existing supplier contract.
- Regularly review and enhance supply chain security practices.
- Source: (National Cyber Security Centre, n.d.)

This Photo by Unknown Author is licensed under CC BY

Supply chain cybersecurity risks

❑ Five-step approach to assessing supply chain cybersecurity

- **Step 1 – Understand why your organisation should care**

➢ Secure commitment from management on its importance.

➢ Identify critical assets and data shared with suppliers.

➢ Assess potential threats and vulnerabilities across processes.

➢ Evaluate potential impact of breaches on organizational operations.

This Photo by Unknown Author is licensed under CC BY-NC-ND

Supply chain cybersecurity risks

❑ Five-step approach to assessing supply chain cybersecurity

- **Step 2 - Develop an approach to assess supply chain cyber security**

➢ Create supplier security profiles based on risk levels.

➢ Define minimum security requirements for each profile.

➢ Establish assessment methods (e.g., questionnaires, audits).

➢ Plan for scenarios where suppliers may not meet security expectations.

This Photo by Unknown Author is licensed under CC BY-SA

Supply chain cybersecurity risks

❑ Five-step approach to assessing supply chain cybersecurity

- **Step 3 - Apply the approach to new supplier relationships**

➢ Incorporate security assessments into procurement processes.

➢ Educate procurement teams on the importance of supplier security.

➢ Ensure contractual agreements include defined security obligations.

This Photo by Unknown Author is licensed under CC BY-SA

Supply chain cybersecurity risks

❑ Five-step approach to assessing supply chain cybersecurity

- **Step 4 - Integrate the approach into existing supplier contracts**

➢ Identify and prioritize existing suppliers based on criticality.

➢ Conduct security assessments for high-priority suppliers.

➢ Amend contracts to include necessary security clauses.

➢ Collaborate with suppliers to address identified security gaps.

This Photo by Unknown Author is licensed under CC BY-SA

Supply chain cybersecurity risks

❑ Five-step approach to assessing supply chain cybersecurity

- **Step 5 – Continuous Improvement**

➢ Monitor supplier security performance regularly.

➢ Stay informed about emerging threats and adjust strategies accordingly.

➢ Engage in continuous dialogue with suppliers to enhance security measures.

➢ Report progress and challenges to organizational leadership.

This Photo by Unknown Author is licensed under CC BY-NC

Supply chain cybersecurity risks

- **2024: Worldwide tech outages impacting airlines, businesses running Microsoft software**

https://www.youtube.com/watch?v=96j6-DqPKsk

Faulty software update: A configuration update pushed by CrowdStrike's Falcon endpoint detection and response (EDR) software contained a logic error.

This triggered repeated Blue Screens of Death (BSOD) and bootloops on Windows systems.

Risk management framework

❑ What Is ISO/IEC 27001?

- ISO/IEC 27001 is an international standard for managing information security through an Information Security Management System (ISMS) (ISO, 2022).

- **Issued by:**

➢ ISO (International Organization for Standardization)

➢ IEC (International Electrotechnical Commission)

- **Goal:** Provide a systematic approach to managing security risks.

- **Key Feature:** Risk-based approach focused on continuous improvement.

This Photo by Unknown Author is licensed under CC BY-SA

Risk management framework

❑ ISO/IEC 27001 Explained

This Photo by Unknown Author is licensed under CC BY-SA

https://www.youtube.com/watch?v=x792wXSeAhA&t=103s

Risk management framework

- **ISO/IEC 27001 – ISMS key components**

- Information security policy – sets the direction.
- Risk assessment and treatment plan – tailored to the organization.
- Statement of applicability (SoA) – documents control choices.
- Internal audits – assess ISMS effectiveness.
- Management reviews – ensure top-level oversight.
- Continual improvement cycle (Plan-Do-Check-Act).

This Photo by Unknown Author is licensed under CC BY-SA

Risk management framework

- **What Is the NIST Risk Management Framework (RMF)?**

- A structured process developed by the **National Institute of Standards and Technology (NIST)** for managing cybersecurity risks.

- Originally designed for **U.S. federal agencies**, but widely adopted across industries.

- Aligns security and risk management activities with organizational goals.

National Institute of Standards and Technology
U.S. Department of Commerce

This Photo by Unknown Author is licensed under CC BY

Risk management framework

SIM Global Education

❑ Core principles of NIST RMF

- Risk-based decision making – Prioritizes security controls based on risk tolerance.
- System development life cycle (SDLC) – Integrates security from design to decommissioning.
- Organizational alignment – Ensures leadership engagement and enterprise-level strategy.
- Continuous monitoring – Promotes real-time risk response and adaptation.

NIST
National Institute of Standards and Technology
U.S. Department of Commerce

This Photo by Unknown Author is licensed under CC BY

Incident response planning

❑ What is a computer security incident?

- Refers to **a violation or imminent threat of violation** of: computer security policies, acceptable use policies, or standard security practices.

- **Examples:**

➢ A DoS attack - sending high volumes of connection requests to a web server, causing it to crash.

➢ Tricked to open an attached “quarterly report” (malware) in an email infected their computers.

➢ Sensitive data breach, attacker threatens to release publicly if designated sum of money not paid.

This Photo by Unknown Author is licensed under CC BY-SA

Incident response planning

SIM Global Education

❑ Incident response policy

- Defines approach to incident response, guiding preparation, response, and post-incident activities.

- **Objectives:**

➢ Establish roles and responsibilities.

➢ Provide governance over how incidents are detected, reported, and handled.

➢ Ensure compliance with regulations and internal controls.

➢ Provides foundation for more detailed **Incident Response Plan**.

➢ **Key Point:** Without a defined policy, incident handling becomes inconsistent, delayed, and ineffective.

Incident response planning

❑ Incident response plan

- Structured approach to handle and manage the aftermath of a security breach or cyberattack.
- **Why it's critical:**

➢ Reduces damage and recovery time.

➢ Minimizes operational disruption.

➢ Protects sensitive data.

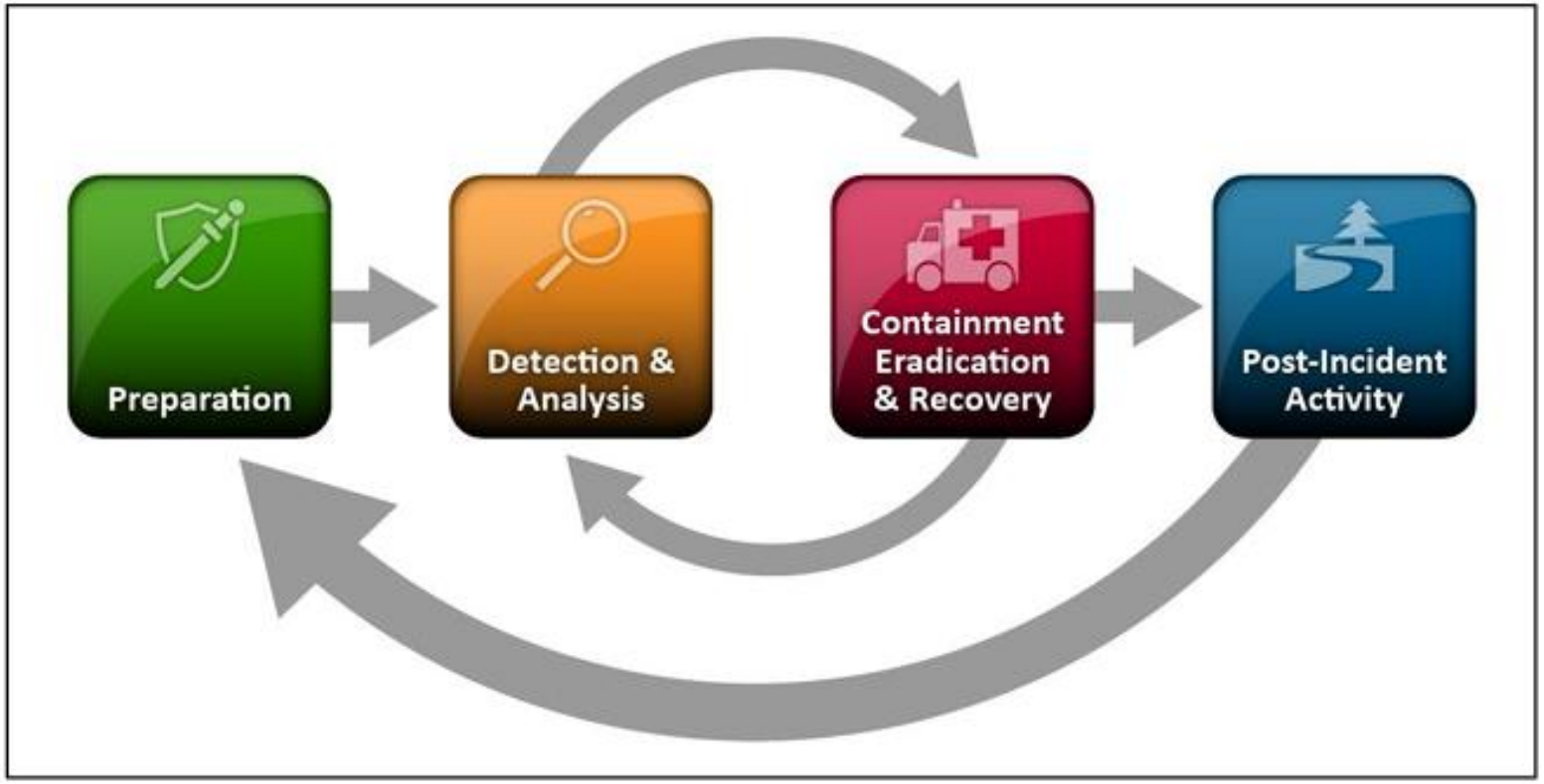
➢ Helps comply with regulations.

➢ Supports fast recovery and continuity.

Source: Skyword Technical Solutions

Incident response planning

❑ Phases of incident response plan



Source: (NIST, 2012)

Incident response planning

❑ Phases of incident response plan

- **Preparation :** Establish response team, roles, tools.
- **Detection and analysis :** Detect and confirm the incident through monitoring and alerts.
- **Containment :** Short-term: stop spread and Long-term: apply fixes and segregate systems.
- **Eradication :** Remove threat from environment (e.g., malware removal, vulnerability patching).
- **Recovery :** Restore systems, verify integrity, monitor for re-infection.
- **Post incident activities :** Conduct post-incident review and update response strategies to improve defences.

Incident response planning

❑ Use of automated tools in incident response management

- **Objectives:**

➢ Accelerates incident detection and response.

➢ Reduces human error and improves consistency.

➢ Enhances threat visibility across complex environments.

➢ Supports 24/7 monitoring and faster containment.

This Photo by Unknown Author is licensed under CC BY-SA-NC

Incident response planning

❑ Use of automated tools in incident response management

- **Functions:**

➢ **Prevention:** Proactively block or minimize threats

➢ **Detection:** Identify suspicious activity in real time

➢ **Deterrence:** Discourage attackers through visible controls and rapid response

This Photo by Unknown Author is licensed under CC BY-SA-NC

Incident response planning

❑ Use of automated tools in incident response management

Function	Tool Type	Example
Prevention	Firewalls, Endpoint Protection	Cisco ASA, CrowdStrike Falcon
	Patch Management Systems	Microsoft SCCM, Ivanti
	Anti-spam/Anti-Malware software	Proofpoint Email Protection, CrowdStrike Falcon
Detection	Intrusion Detection/Prevention Systems (IDS/IPS)	Snort, Suricata, Palo Alto Networks
	Security Information and Event Management (SIEM)	Splunk, IBM QRadar, LogRhythm
	File Integrity Checking Software	Tripwire Enterprise
	User and Entity Behavior Analytics (UEBA)	Exabeam, Azure Sentinel
Deterrence	Network Access Control (NAC)	Cisco ISE, Aruba ClearPass
	Deception Technologies	Illusive, TrapX
	Automated Incident Response (SOAR)	Cortex XSOAR, IBM Resilient

Incident response planning

❑ Incident response team

- Provides communications with outside parties for liability and evidentiary purposes.
- Source: (NIST, 2012)

Incident response planning

❑ Role of awareness and education

- Many security incidents stem from human error or lack of awareness.
- Human is often the weakest link.
- Training helps staff recognize threats early (e.g., phishing, social engineering)
- Builds a "security-first" culture across all departments
- **Key Benefits:**

➢ Faster identification and reporting of incidents

➢ Fewer unintentional violations of security policies

➢ Empowered employees act as the first line of defense

This Photo by Unknown Author is licensed under CC BY-NC-ND

Incident response planning

❑ Role of awareness and education

- **Training content should cover:**

➢ How to recognize suspicious activity (e.g., phishing emails)

➢ How and where to report incidents

➢ Roles and responsibilities during a security incident

➢ Secure use of company systems and data

Incident response planning

- **AI powered cyber attacks**

https://www.youtube.com/watch?v=IDDmAZuXLi4

AI for cybersecurity management

❑ Threats of AI

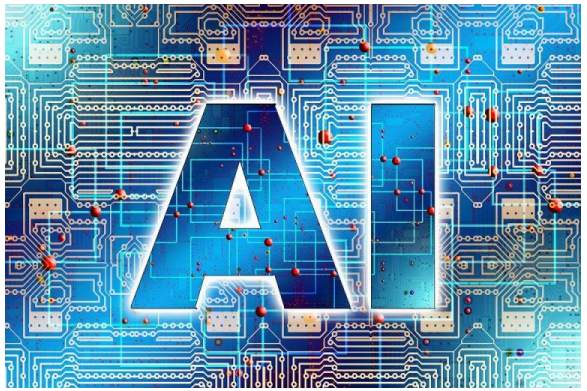
- **Automated phishing & social engineering**
  - Can craft highly convincing, personalized phishing emails at scale.
  - Deepfakes (audio/video) impersonate trusted people (e.g., CEOs, partners).
- **Advanced malware & evasion tactics**
  - AI-generated malware can mutate dynamically to bypass traditional antivirus.
  - Adaptive attacks that evolve based on target behaviours or defence systems.
- **AI-driven reconnaissance**
  - Can rapidly scan and map systems for vulnerabilities with minimal noise.
  - Intelligent botnets can coordinate stealthier, more effective attacks.
- **Exploitation of defensive AI**
  - Attackers may reverse-engineer or poison AI used in defence (e.g., false training data).
  - Adversarial attacks: subtle inputs that mislead AI models into making wrong decisions.

This Photo by Unknown Author is licensed under CC BY-SA

AI for cybersecurity management

❑ Role of AI in cybersecurity management

- **Threat detection:** Identifies anomalous behaviour in real-time (e.g., insider threats, lateral movement)
- **Incident response:** Automates triage and containment using AI-driven Security Orchestration, Automation, and Response (SOAR) platforms.
- **Malware analysis:** Uses machine learning to detect zero-day threats and polymorphic malware.
- **Phishing protection:** Natural Language Processing (NLP) helps flag phishing emails with high accuracy.



This Photo by Unknown Author is licensed under CC BY

Quantum computing and future cybersecurity

SIM Global Education

- **What is Quantum Computing?**

- Leverages quantum bits (qubits) to perform complex calculations exponentially faster than classical computers.
- **Threats to current cybersecurity models**
  - Cryptographic risk: Algorithms like RSA and ECC could be broken by Shor's algorithm on a quantum computer.
  - Post-quantum cryptography (PQC): NIST is leading standardization of quantum-resistant algorithms.
  - Quantum-resilient security: Organizations to test and adopt quantum-safe encryption
- **Example:**
  - Google & IBM: Researching quantum algorithms that may break current public key encryption

ACTIVITY

❑ Exercise: Answering discussive questions

1. How can individuals and organisations better protect themselves against evolving cybersecurity threats, such as AI-powered attacks and social engineering?

2. Why is compliance and ethical decision-making critical in cybersecurity, and how can transparency improve trust and security?

3. How do emerging technologies like AI and quantum computing create both opportunities and risks in cybersecurity, and how should businesses adapt?

SIM Global Education

ACTIVITY

❑ Exercise: Answering discussive questions

- Activity (Time: 25 mins)
- Go to https://docs.google.com/document/d/1TaG3FqfNEl-y3scHD-5Z7RPEB_3CcskBGHHNLEm6nTg/edit?usp=sharing.
- Work in pairs to answer the questions. Type your answers using the google document.
- Discuss your answers in class.

ACTIVITY

What have you learnt today?

- Go to **joinmyquiz.com** to take a quiz.

Lecture 7 recap

You should be able to answer these key questions:

1. What is the difference between a threat and a vulnerability in the context of IT risks?
2. How do you define the impact of an IT security incident?
3. What are the key steps in conducting a risk assessment
4. What is a risk assessment matrix, and how is it used in managing IT risks?
5. How does mass surveillance differ from targeted surveillance?
6. What are the four types of risk response strategies, and when might each be appropriate?
7. Why should we be concerned about the societal implications of mass surveillance?
8. What is the difference between feeling safe and being safe?
9. What is security theatre, and why can it be harmful to effective security practices?

Reference

https://www.imperva.com/learn/application-security/cyber-security-threats/?utm_source=chatgpt.com

https://www.terranovasecurity.com/blog/examples-of-social-engineering-attacks?utm_source=chatgpt.com

https://www.augusta.edu/online/blog/cybersecurity-ethics?utm_source=chatgpt.com

https://www.gartner.com/en/articles/information-security?utm_source=chatgpt.com

https://www.reuters.com/world/us/fbi-says-cybercrime-costs-rose-least-16-billion-2024-2025-04-23/

National Cyber Security Centre (NCSC). (n.d.). Understanding the threat to the supply chain. Retrieved from https://www.ncsc.gov.uk/collection/assess-supply-chain-cyber-security/understanding-the-threat

Snape, G. (2025, February 19). Supply chain cyber attacks surge over 400%, expected to continue rising – Cowbell report. *Insurance Business America*. https://www.insurancebusinessmag.com/us/news/cyber/supply-chain-cyber-attacks-surge-over-400-expected-to-continue-rising--cowbell-report-525369.aspx:contentReference[oaicite:4]{index=4}

Committee of Inquiry. (2019). *Public Report of the Committee of Inquiry into the Cyber Attack on SingHealth*.

Reference

National Institute of Standards and Technology. (2012). *Computer security incident handling guide* (Special Publication 800-61 Revision 2). https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf

Henretta, J. (2024, February 8). *Creating an effective incident response plan*. Skyward IT. https://skywardit.com/blog/creating-an-effective-incident-response-plan/

Schneier, B. *Data and Goliath: The hidden battles to collect your data and control your world.* (New York: W.W. Norton & Company, 2016). Chapter 5.

Stoneburner, G., Goguen, A., & Feringa, A. (2002). *Risk management guide for information technology systems* (NIST Special Publication 800-30). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-30

Taylor, A., Fruhlinger, J., Haskell-Dowland, P., Patel, U., & Rashid, A. (2020). *Information security management principles* (3rd ed.). BCS Learning & Development Limited.

National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments* (Special Publication 800-30 Rev. 1). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-30r1